CPTS Report

When the exam starts

- Meta
- Document Control
- Executive Summary (Most of it when the exam starts)
  - Assessment Overview and Recommendations (Later)
- Network Penetration Testing Assessment Summary

Most these fields are fairly standard and require little to no modifications. Read them carefully and decide for yourself if you need to change something or leave as is.

When A Host Or Service Is Discovered

- Once you discover a live host and enumerate the available services (e.g., via an Nmap scan), you should fill in the appropriate appendix:
  - - Appendix
    - Host & Service Discovery
      - For each discovered host, create a table with the following columns:
        - Heading that identifies which host the information pertains to.

Column	Explanation
Port The port(s)	where the discovered service is running. E.g., "80"
Service	The name and version of the service. E.g., "nginx 1.18.0"
Notes	Any additional notes you have. E.g., "Hosts a custom support web application."

When A Virtual Host Or Subdomain Is Discovered

- You should fill in the appropriate appendix with both the domains provided in the scope of the engagement (if any) and those you discover during your penetration test:
  - Appendix
    - Subdomain Discovery

Column	Explanation
URL	The URL of the domain. E.g., "admin.target.htb"
Description	A description of what the domain is used for. E.g., "Administrator dashboard for the web application."
Discovery Method	How you discovered it. E.g., "Revealed in HTML comment."

When A Security Finding Is Discovered

Findings
Examples in the following link https://academy.hackthebox.com/module/162/section/1536
Fill out all the fields:

- Findings
  - Title
    - For the Title, while it can be challenging to come up with, there's no strict standard you need to follow. As long as your title is clear and consistent, you can name the findings as you see fit. Here are some example titles based on those I compiled from Hack The Box sources that might inspire you:
      - Insecure File Shares
        Sensitive Data on File Shares
        Unnecessary Exposed Services
        Insecure Direct Object Reference (IDOR)
        HTTP Verb Tampering
        Unrestricted File Upload
        Local File Inclusion (LFI)
        Weak <APPLICATION> Admin Credentials
        SQL Injection
        Cross-Site Scripting (XSS)
        SSRF to Local File Read
        XML External Entity (XXE) Injection
        Command Injection
        Excessive Active Directory Group Privileges
        Passwords in AD User Description Field
        Misconfigured <APPLICATION> Instance
        - Remember, each security finding should be documented individually. Don't group multiple vulnerabilities, like SQL Injection, into a single finding.
- CWE
  - For the CWE, if you're unsure, you can ask ChatGPT which CWE fits the vulnerability. Then, validate it by Googling <CWE> MITRE and reviewing the description.
- CVSS
  - For CVSS, use the CVSS calculator built into SysReptor or find one online. If you need assistance, ChatGPT can help, but make sure to verify the result yourself.
- Overview
  - Provide a high-level explanation of the vulnerability both generally and in the context of your finding. Avoid covering the impact or remediation here, as those will be addressed in later fields.
- Impact
  - In the Impact section, describe the security implications of the vulnerability if it remains in the client's environment. Provide specific examples relevant to this instance of the vulnerability. You can present this information as a paragraph or a bullet-point list, but keep the format consistent across all findings.
- Affected Components
  - In the Affected Components field, provide the smallest label that encompasses all the components affected by the vulnerability. For example:
    - If a vulnerability affects a single host or service, use a label that includes both the host and the service if relevant, like "HOST01 (SMB / 139,445 TCP)". (e.g. EternalBlue)
    - If it affects a specific subdomain, use a label such as app.target.htb. (e.g. SQLi on a web application)
    - For vulnerabilities affecting an entire subnetwork or an Active Directory environment, don't list each host individually. Instead, use a label like "target.htb Active Directory domain" or an IP range, such as 10.0.0.0/8. (e.g. Kerberoasting)
- Recommendations
  - In the Recommendations field, provide actionable steps to address the vulnerability. Never attempt to fix the issue yourself, such as by providing a "fixed" version of code. Instead, guide the client on how to resolve the issue. Each vulnerability covered in the course has an Academy section with mitigation suggestions that you can use as reference when writing recommendations. You can present these actions as a bullet-point list.
    - We should tie each recommendation back to a specific finding and not include any short or medium-term recommendations that are not actionable by remediating findings reported later in the report. Long-term recommendations may map back to informational/best practice recommendations such as "Create baseline security templates for Windows Server and Workstation hosts" but may also be catch-all recommendations such as "Perform periodic Social Engineering engagements with follow-on debriefings and security awareness training to build a security-focused culture within the organization from the top down."
- References
  - In the References field, include links to resources related to the security finding. Useful references might include:
    - The NIST page for the CVE if applicable, and any relevant blog posts by the researcher.
    - The MITRE page for the CWE, if available.
    - An OWASP Prevention Cheatsheet for the vulnerability, if there is one.
    - If you used a Proof of Concept (PoC) script you haven't wrote yourself, provide a link.
- Details
  - Lastly, in the Details field, provide a step-by-step procedure to reproduce the discovery and exploitation of the finding, including explanations for each step. Be sure to include:
    - - Plenty of images and code blocks to illustrate your points.
    - - Label all images and code blocks clearly.
    - - Highlight important lines in code blocks.
    - - Crop images to show only the relevant portions.
    - - Redact any sensitive information from both images and code blocks.
    - - Mention tools and scripts used.

Remediation Summary

- With the finding section complete, take a moment to fill in the fields related to the Remediation Summary section by adding recommendations for addressing this specific finding. In this step, you can generally copy-paste the remediation actions you suggested in the finding's Recommendation field and distribute them across Short Term, Medium Term, and Long Term fields as appropriate. By the end of the engagement, you should have a bullet point list of short, medium, and long-term remediation actions for all the security findings you discovered.
  - - **Short Term**
  - - **Medium Term**
  - - **Long Term**
- Effective Remediation Recommendations
  - Example 1
    - Bad: Reconfigure your registry settings to harden against X.
    - Good: To fully remediate this finding, the following registry hives should be updated with the specified values. Note that changes to critical components like the registry should be approached with caution and tested in a small group prior to making large-scale changes.
      - [list the full path to the affected registry hives]
        - Change value X to value Y
  - Example 2
    - Bad: Implement [some commercial tool that costs a fortune] to address this finding.
    - Good: There are different approaches to addressing this finding. [Name of the affected software vendor] has published a workaround as an interim solution. For the sake of brevity, a link to the walkthrough has been provided in the reference links below. Alternatively, there are commercial tools available that would make it possible to disable the vulnerable functionality in the affected software altogether, but these tools may be cost-prohibitive.

Executive Summary

- Do
  - When talking about metrics, be as specific as possible.
  - It's a summary. Keep it that way.
  - Describe the types of things you managed to access -
  - Describe the general things that need to improve to mitigate the risks you discovered.
  - If you're feeling brave and have a decent amount of experience on both sides, provide a general expectation for how much effort will be necessary to fix some of this.
- Do Not
  - Name or recommend specific vendors.
  - Use Acronyms.
    - Vocabulary Changes
      - This list is not exhaustive nor the "right" way to describe these things. They are meant as examples of how you might describe a technical topic in a more universally understandable way.
        - VPN, SSH - a protocol used for secure remote administration
        - SSL/TLS - technology used to facilitate secure web browsing
        - Hash - the output from an algorithm commonly used to validate file integrity
        - Password Spraying - an attack in which a single, easily-guessable password is attempted for a large list of harvested user accounts
        - Password Cracking - an offline password attack in which the cryptographic form of a user's password is converted back to its human-readable form
        - Buffer overflow/deserialization/etc. - an attack that resulted in remote command execution on the target host
        - OSINT - Open Source Intelligence Gathering, or hunting/using data about a company and its employees that can be found using search engines and other public sources without interacting with a company's external network
        - SQL injection/XSS - a vulnerability in which input is accepted from the user without sanitizing characters meant to manipulate the application's logic in an unintended manner
  - Spend more time talking about stuff that doesn't matter than you do about the significant findings in the report.
  - Use words that no one has ever heard of before.
  - Reference a more technical section of the report.

Anatomy of the Executive Summary

- The first thing you'll likely want to do is get a list of your findings together and try categorizing the nature of the risk of each one. These categories will be the foundation for what you're going to discuss in the executive summary. In our sample report, we have the following findings:
  - LLMNR/NBT-NS Response Spoofing - configuration change/system hardening
  - Weak Kerberos Authentication ("Kerberoasting") - configuration change/system hardening
  - Local Administrator Password Re-Use - behavioral/system hardening
  - Weak Active Directory Passwords - behavioral
  - Tomcat Manager Weak/Default Credentials High - configuration change/system hardening
  - Insecure File Shares - configuration change/system hardening/permissions
  - Directory Listing Enabled - configuration change/system hardening
  - Enhance Security Monitoring Capabilities - configuration change/system hardening

When The Engagement Is Done

- The fields that need to be filled or revisited are:
  - Executive Summary
    - Assessment Overview and Recommendations
  - Remediation Summary
    - - **Short Term**
    - - **Medium Term**
    - - **Long Term**
  - Appendix
    - Domain Password Review
- An appendix not included in the SysReptor template but recommended by the course material is **Domain Password Review**.
  - In this appendix, you'll provide statistics on the passwords of Active Directory domain users after achieving domain compromise and dumping NTDS.dit. Key statistics to include are:
    - - Number of hashes obtained
    - - Number of unique hashes
    - - Percentage of hashes cracked
    - - Most commonly used passwords
    - - Password length breakdown

Now that you have a complete walkthrough of the attack path in the Detailed Walkthrough field, it's time to fill in the Assessment Overview and Recommendations section of the Executive Summary.

- Assessment Overview and Recommendations
  - For this section, you'll provide a plain-English summary of the attack path and your overall takeaways from the engagement. Avoid technical jargon, bullet points, and code blocks, as this part is intended for a non-technical audience.
  - Start with a paragraph on your overall assessment of their security posture. Reflect on the security findings and what they reveal about the client's security practices. For instance, if no password spray attack succeeded, praise their strong password policy.
  - Then, write a paragraph for each security finding in the attack chain. Explain each vulnerability in simple terms that anyone can understand (without sounding patronizing) and include straightforward remediation suggestions.
  - The default text for this field is well-written, so definitely keep it and insert your own text where indicated.

Short Term, Medium Term, Long Term remediation fields

- After that, revisit the Short Term, Medium Term, and Long Term remediation fields. By now, you should have remediation actions related to the specific security findings listed. However, it's also important to add recommendations that address the overall security posture of the organization.
- For example, if many findings were related to outdated software with known CVEs, you should recommend reviewing and improving their software update procedures. Additionally, offer broad advice such as conducting regular security audits and staying up to date with best practices

When You Get Foothold On A Host

When You Get Foothold On A Host

- Once you gain command execution on a host, it's time to add it as exploited to the appropriate appendix.

  You'll also document the steps for this initial compromise in the compromise walkthrough.
  - Internal Network Compromise Walkthrough
    - Walkthrough Summary
      - For the compromise walkthrough, start by reviewing the Walkthrough Summary field. Make any necessary adjustments and see if it looks good to you. Feel free to rephrase it in your own words if needed, but otherwise you can leave it as is.
    - Detailed Walkthrough
      - For the Detailed Walkthrough, you'll document the steps related to the host you just exploited. Use the following structure, which is divided into two parts:
        - {{ report.candidate.a_name }} ("the tester" herein) performed the following to fully compromise the <DOMAIN> domain.
          - <Here, include a numbered bullet point list where each point outlines a step in the attack chain.>
            - Bullet Point List: Keep it concise and focused. It's fine to have multiple points for a single finding, but don't overdo it. Don't include images, code blocks, or any extraneous details.
        - Detailed reproduction steps for this attack chain are as follows:
          - <Here, provide detailed steps in a writeup format.>
            - Detailed Walkthrough: Describe the steps thoroughly in a writeup format. Be highly descriptive and explain each technique or action in detail, at least once. Include plenty of images and code blocks—when in doubt, err on the side of including too many rather than too few. Add pertinent comments where appropriate, such as acknowledging effective security measures.

For both parts, exclude any findings unrelated to the shortest attack path to domain compromise. Write in the third person, referring to yourself as "the tester." As you compromise more hosts during the engagement, this field will gradually fill up, resulting in a complete walkthrough of the attack chain by the end.

- Appendix
  - Exploited Hosts
    - For the Exploited Hosts appendix, fill in a table with the following columns for each host:

Column	Explanation
Host	The hostname and IP address of the host. E.g., "HOST01 (192.158.1.38)"
Scope	Indicate either "External" or "Internal," depending on whether the host is external-facing or internal (e.g., in a DMZ).
Method	Describe the exploitation method used to compromise the host. E.g., "Command injection on web application."
Notes	Include any additional notes about the host. E.g., "Domain Controller for target.htb."

When You Root A Host

When You Root A Host

- Once you've gained the highest local privilege on a host (root or SYSTEM), fill out the following fields:
  - Internal Network Compromise Walkthrough
    - Detailed Walkthrough
      - For the Detailed Walkthrough, you'll document the steps related to the host you just exploited. Use the following structure, which is divided into two parts:
        - {{ report.candidate.a_name }} ("the tester" herein) performed the following to fully compromise the <DOMAIN> domain.
          - <Here, include a numbered bullet point list where each point outlines a step in the attack chain.>
            - Bullet Point List: Keep it concise and focused. It's fine to have multiple points for a single finding, but don't overdo it. Don't include images, code blocks, or any extraneous details.
        - Detailed reproduction steps for this attack chain are as follows:
          - <Here, provide detailed steps in a writeup format.>
            - Detailed Walkthrough: Describe the steps thoroughly in a writeup format. Be highly descriptive and explain each technique or action in detail, at least once. Include plenty of images and code blocks—when in doubt, err on the side of including too many rather than too few. Add pertinent comments where appropriate, such as acknowledging effective security measures.
      - Appendix
        - Changes/Host Cleanup

First, take a moment to recall all the changes you made to the host since gaining a foothold. This could include actions like adding a web shell, transferring an executable, creating a local user, etc.

Even if you reverted a change, such as deleting a PoC script after using it, it's important to document it in the report. The transfer might have triggered an EDR alert, and the client will need to know whether it was part of the pentest or a potential breach.

- After compiling your list, add a table to the Changes/Host Cleanup appendix with the following columns:
  - Heading to identify which host the changes relate to

Column	Explanation
Host	The hostname and IP address of the host. E.g., "HOST01 (192.158.1.38)"
Scope	Indicate either "External" or "Internal," depending on whether the host is external-facing or internal (e.g., in a DMZ).
Change/Cleanup Needed	A description of the change made. If it involves creating or transferring a file, include the MD5 sum. E.g., "Uploaded a web shell to /var/www/html/shell.php. MD5: 6ea3393fd7a4544d2fda0e42d7634013"

the Detailed Walkthrough

- After documenting the changes, include the steps for this compromise in the Detailed Walkthrough field, both in the bullet point list and the detailed writeup.

When You Compromise A User

When You Compromise A User

- Once you gain control of a user, whether by obtaining their passwords, NTLM hash or however else, add this information to the appropriate appendix.
  - Appendix
    - Compromised
      - I recommend creating one table for local users and another for each Active Directory domain where you've compromised a user. Alternatively, you could create a separate table for local users on each individual host if that works better for you.
        - The tables should include the following columns:
          - Heading identifying the host or domain they are associated with.

Column	Explanation
Username	The username for the user. E.g., "www-data"
Method	The method you used to gain control over this user. E.g., "Kerberoasted"
Notes	Notes about the user. For local users, specify the host they belong to. If the user has a specific purpose, mention that too. E.g., "HOST01's local user for Tomcat service."

When You Capture A Flag

When You Capture A Flag

- Appendix
  - Flags Discovered

Column	Explanation
Flag #	The flag number. Sort the rows in ascending order. E.g., "9."
Host	The hostname of the host where the flag was found. E.g., "HOST01"
Flag Value	The exact value of the flag as found.
Flag Location	Where the flag was found. If it was in a file, provide the full path. E.g., "/root/flag.txt"
Method Used	The method used to exploit your way to the flag. E.g., "Privilege escalation via sudo rights over the wget binary."

Presented with xmind